Анализ и обнаружение использования встроенных механизмов Microsoft SQL Server в контексте пост-эксплуатационной активности

Задание

Исследовать встроенные механизмы Microsoft SQL Server, потенциально применимые для выполнения действий на уровне операционной системы при наличии повышенных привилегий. Провести анализ сценариев пост-эксплуатационного воздействия, серию экспериментов, проанализировать артефакты в средствах журналирования и определить методы обнаружения и предотвращения злоупотребления расширенной функциональностью SQL Server

Реферат

MICROSOFT SQL SERVER, ИНФОРМАЦИОННАЯ БЕЗОПАСНОСТЬ, ПОСТ-ЭКСПЛУАТАЦИЯ, XP_CMDSHELL, OLE AUTOMATION, SQL SERVER AGENT, ЖУРНАЛИРОВАНИЕ, WINDOWS EVENT LOG, SYSMON, МОНИТОРИНГ, ОБНАРУЖЕНИЕ АНОМАЛИЙ, ЭКСПЛУАТАЦИЯ ПРИВИЛЕГИЙ, СУБД, КОРРЕЛЯЦИЯ СОБЫТИЙ

Целью работы является исследование встроенных механизмов Microsoft SQL Server, которые при неправильной конфигурации или наличии избыточных привилегий могут быть использованы для выполнения действий на уровне операционной системы.
Объектом исследования являются механизмы xp_cmdshell, OLE Automation и SQL Server Agent Jobs, а также их поведенческие и журнальные артефакты.
Методами исследования являются развертывание изолированной лабораторной среды, проведение контролируемых экспериментов, анализ журналов SQL Server и операционной системы, а также сопоставление событий с помощью средств мониторинга.
В ходе работы выполняется анализ поведения СУБД при активации встроенных функций, выявляются особенности их наблюдаемости и ограничения стандартных средств журналирования.
Итоговый результат представляет собой исследование моделей обнаружения пост-эксплуатационной активности в Microsoft SQL Server и формирование практических рекомендаций по повышению защищенности СУБД.

Содержание

- Введение
- Механизмы потенциального пост-эксплуатационного воздействия в Microsoft SQL Server
  - xp_cmdshell
  - OLE Automation
  - SQL Server Agent Jobs
- Практическая задача
- Лабораторный стенд и эксперимент
  - Архитектура эксперимента
  - Сценарии эксперимента
- Проведение эксперимента
  - xp_cmdshell
  - SQL Server Agent Jobs
  - OLE Automation
- Методы защиты
  - xp_cmdshell
  - OLE Automation
  - SQL Server Agent Jobs
  - Общий подход к защите
- Заключение

- Список литературы

Введение

Несмотря на развитые механизмы разграничения доступа и аудита, SQL Server содержит ряд встроенных функциональных возможностей, предназначенных для администрирования и расширения функциональности системы. При наличии избыточных привилегий или некорректной конфигурации данные механизмы могут быть использованы для выполнения действий, выходящих за рамки стандартной работы СУБД, включая взаимодействие с операционной системой.
Особый интерес с точки зрения информационной безопасности представляют сценарии пост-эксплуатационного воздействия, при которых злоумышленник, получивший доступ к СУБД, может использовать её встроенные функции для закрепления в системе, выполнения системных команд и расширения уровня контроля над инфраструктурой. К таким механизмам относятся xp_cmdshell, OLE Automation и SQL Server Agent Jobs, обладающие потенциально высокой степенью влияния на безопасность системы.
Цели и задачи:

Цель: исследование встроенных механизмов Microsoft SQL Server, потенциально применимых для пост-эксплуатационного воздействия на систему, а также анализ их наблюдаемости средствами журналирования и мониторинга.

Задачи:
а) Изучение функциональных возможностей механизмов xp_cmdshell, OLE Automation и SQL Server Agent Jobs
б) Развертывание изолированной лабораторной среды для проведения экспериментов
в) Проведение контролируемых сценариев активации встроенных функций SQL Server
г) Анализ артефактов, формируемых в журналах SQL Server, Windows Event Log и средствах мониторинга ОС
д) Разработка подходов к выявлению и предотвращению злоупотребления встроенными механизмами СУБД

Объект исследования: встроенные механизмы Microsoft SQL Server, потенциально применимые для выполнения действий на уровне операционной системы.

В ходе исследования использовались методы развертывания лабораторного стенда, проведения контролируемых экспериментов, анализа журналов событий и сопоставления активности на уровне СУБД и операционной системы с применением средств мониторинга и аудита.

Механизмы потенциального пост-эксплуатационного воздействия в Microsoft SQL Server

Microsoft SQL Server является одной из наиболее распространенных систем управления базами данных (СУБД) в корпоративной среде, что делает её важным компонентом инфраструктуры с точки зрения информационной безопасности.
В случае компрометации учетных данных или получения несанкционированного доступа к серверу СУБД, злоумышленник может использовать встроенные функциональные возможности SQL Server для выполнения действий, выходящих за рамки работы с базой данных. Такие сценарии относятся к классу пост-эксплуатационной активности и представляют интерес с точки зрения анализа поведения и обнаружения аномалий.
Основные направления потенциального злоупотребления включают:

- Выполнение команд на уровне операционной системы через встроенные механизмы СУБД
- Использование механизмов автоматизации для сохранения активности в системе
- Расширения возможностей выполнения кода через интеграцию с внешними компонентами
- Взаимодействие с системными объектами ОС
- извлечение и перемещение данных в рамках доступных прав
  Отметим, что рассматриваемые механизмы являются легитимной частью функциональности SQL Server, однако при неправильной конфигурации или наличии избыточных привилегий могут быть использованы для выполнения нежелательных действий. Это делает их важным объектом для мониторинга и анализа с точки зрения безопасности

xp_cmdshell

Microsoft SQL Server предоставляет расширенную хранимую процедуру xp_cmdshell, предназначенную для выполнения команд операционной системы.
При её использовании СУБД инициирует запуск системного интерпретатора команд, а выполнение происходит в контексте учетной записи службы сервера.
С точки зрения вирусной аналитики и расследования инцидентов информационной безопасности, данный механизм представляет интерес из-за возможности наблюдения следующих артефактов:

- создание дочернего процесса операционной системы
- связь между процессом SQL Server и системными утилитами
- регистрация событий в журналах ОС
- потенциальной расширение активности за пределы СУБД
  Механизм отключен по умолчанию и требует наличия высоких привилегий, что снижает вероятность его случайного использования в стандартных конфигураций.

OLE Automation

OLE Automation представляет собой механизм взаимодействия СУБД с COM-объектами операционной системы Windows. Он позволяет SQL Server инициировать работу внешних компонентов, что расширяет функциональность СУБД, но одновременно увеличивает поверхность атаки при некорректной настройке.
С точки зрения анализа поведения данный механизм может приводить к:

- созданию COM-объектов
- взаимодействию с системными библиотеками
- потенциальной сетевой активности через внешние компоненты
- выполнению логики вне контекста базы данных

SQL Server Agent Jobs

SQL Server Agent является подсистемой планирования задач, предназначенной для автоматизации административных операций. В контексте безопасности он рассматривается как потенциальный механизм закрепления и сохранения активности в системе, поскольку позволяет выполнять задачи по расписанию.
С точки зрения наблюдаемости, интерес представляют:

- создание и модификация заданий
- выполнение задач в системном контексте
- фиксация событий в системных и прикладных журналах

Практическая задача

Целью практической части работы является исследование встроенных функциональных возможностей MS SQL Server, которые при определённой конфигурации могут быть использованы для выполнения действий на уровне операционной системы, а также анализ их наблюдаемости средствами журналирования.
В рамках работы решаются следующие задачи:

1. Подготовка тестовой среды с намеренно ослабленной конфигурацией для исследования потенциально опасных механизмов.
2. Реализация клиентского приложения, осуществляющего подключение к базе данных и выполнение SQL-запросов, моделирующих различные сценарии взаимодействия с сервером.
3. Проведение серии контролируемых экспериментов, направленных на активацию встроенных механизмов MS SQL Server (таких как xp_cmdshell, OLE Automation, SQL Server Agent и CLR Integration) с использованием безопасных тестовых действий.

4. Анализ системных и прикладных журналов с целью выявления артефактов, возникающих при выполнении указанных действий.
5. Разработка и обоснование методов обнаружения и предотвращения нелегитимного использования встроенных механизмов MS SQL Server.
   Все эксперименты проводятся в изолированной лабораторной среде и направлены исключительно на исследование механизмов обнаружения и защиты.

Лабораторный стенд и эксперимент

Для проведения экспериментов был развернут изолированный лабораторный стенд на базе виртуальной машины.
В качестве среды виртуализации использовалось программное обеспечение vmWare Workstation Pro.
Характеристики виртуальной машины:

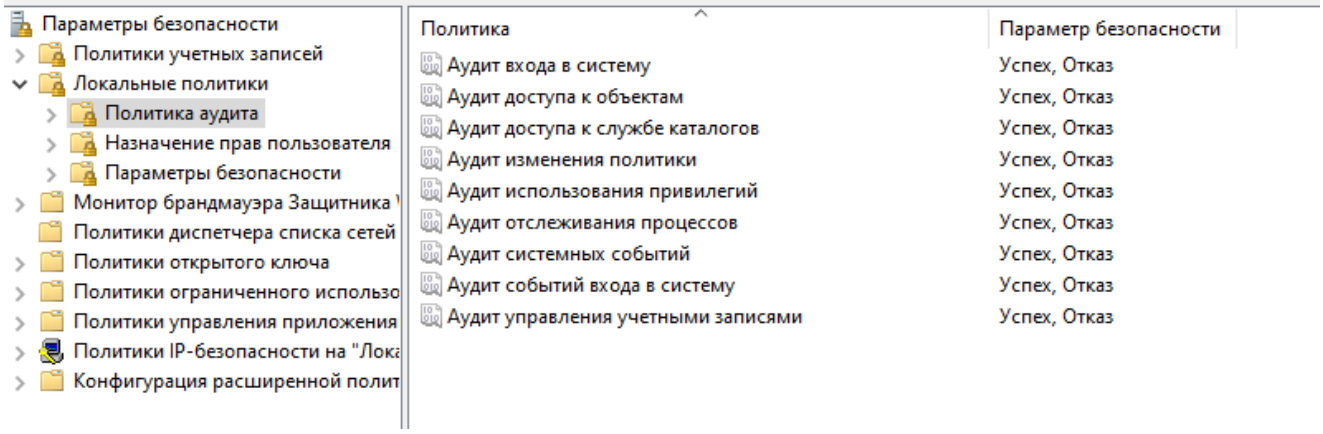
- Операционная система: Windows 10 x64
- Объём оперативной памяти: 4 ГБ
- Тип накопителя: NVMe, объём 100 ГБ
- Сетевая конфигурация: Host-only (без доступа к внешним сетям)
  В качестве системы управления базами данных использовался (версия Express 2022).
  Для тестирования была восстановлена учебная база данных AdventureWorks2022, полученная с официального сайта Microsoft.
  Для анализа активности на уровне операционной системы использовались стандартные средства Windows, а также инструмент, позволяющий фиксировать создание процессов, сетевую активность и операции с файловой системой.

Архитектура эксперимента

Экспериментальная схема включает следующие компоненты:

- клиентское консольное приложение, разработанное на языке C++, выполняющее подключение к SQL Server через интерфейс ODBC;
- сервер баз данных MS SQL Server;
- подсистема журналирования (SQL Server Logs, Windows Event Log, Sysmon).
  Клиентское приложение реализовано в виде консольной программы на языке C++,
  использующей интерфейс ODBC для подключения к MS SQL Server.
  Сценарии и конфигурации безопасности специально ослаблены, включены отключенные по умолчанию инструменты и запущены соответствующие службы.
  Приложение выполняет SQL-запросы, инициируя различные сценарии взаимодействия
  с сервером баз данных. Основной задачей приложения является моделирование
  поведения клиента, выполняющего запросы к базе данных, с целью последующего
  анализа возникающих артефактов в системных журналах.
  Приложение не содержит функциональности, направленной на выполнение вредоносных действий,
  и используется исключительно в рамках контролируемого лабораторного эксперимента.
  Результирующая активность фиксируется на уровне:
- SQL Server (выполнение запросов, изменение конфигурации);
- операционной системы (создание процессов, файловые операции);
- средств расширенного мониторинга (Sysmon).
  Таким образом обеспечивается возможность сопоставления выполняемых SQL-запросов с наблюдаемыми артефактами в различных источниках журналирования.
  На рисунке 1 представлена конфигурация расширенного аудита, установленная для средства журналирования и

просмотра журналов событий Windows Event Log:



Сценарии эксперимента

В рамках работы рассматриваются следующие сценарии:

xp_cmdshell

Исследуется выполнение системных команд через расширенную хранимую процедуру xp_cmdshell.
Целью является выявление артефактов, связанных с запуском дочерних процессов операционной системы от имени процесса SQL Server.
Ожидаемые наблюдения:

- создание процесса cmd.exe;
- родительский процесс — sqlservr.exe;
- фиксация события в журналах Windows и Procmon, в логах SQL Server.

OLE Automation

Исследуется взаимодействие SQL Server с COM-объектами Windows.
В рамках сценария выполняются тестовые операции, инициирующие обращение к системным компонентам.
Ожидаемые наблюдения:

- создание COM-объектов;
- возможная сетевая активность;
- соответствующие записи в журналах системы и SQL Server.

SQL Server Agent Jobs

Исследуется механизм планирования заданий SQL Server Agent.
В рамках сценария создаётся и выполняется тестовое задание.
Ожидаемые наблюдения:

- запись о создании задания в системной базе msdb;
- события выполнения задания;
- фиксация активности в журналах SQL Server, Windows Event Logs, Procmon.

Проведение эксперимента

xp_cmdshell

Запустив пользовательское приложение, и удостоверившись в корректном выполнении запроса, результат которого представлен на рисунке 2, можно перейти к исследованию средств журналирования.

```
C:\Users\johndou\source\repos\Exploitation\x64\Debug\xpcmdshell.exe
Attempting connection to SQL Server

Successfully Connected to SQL Server

Executing SQL query...

Query Result:
nt service\mssqlserver

Query Result:
nt service\mssqlserver

Press any key to exit...
```

Сведения об использовании xp_cmdshell можно собрать по связанным с ним событиям. Приведем подробные логи из Windows Event Logs в таблице 1

Источник	Код события	Категория задачи	Общие сведения
MSSQLSERVER	33090	Сервер	Выполнена попытка загрузить библиотеку "xplog70.dll" в память.
MSSQLSERVER	8128	Сервер	Используется "xplog70.dll" версия "2025.170.1000" для выполнения расширенной хранимой процедуры "xp_msver".
MSSQLSERVER	33090	Сервер	Выполнена попытка загрузить библиотеку "xpsqlbot.dll" в память
MSSQLSERVER	8128	Сервер	Используется "xpsqlbot.dll" версия "2025.170.1000" для выполнения расширенной хранимой процедуры "xp_qv".
MSSQLSERVER	33090	Сервер	Выполнена попытка загрузить библиотеку "xpstar.dll" в память.
MSSQLSERVER	8128	Сервер	Используется "xpstar.dll" версия "2025.170.1000" для выполнения расширенной хранимой процедуры "xp_regread".

Сведения их журнала MS SQL Server приведены в таблице 2:

Источник	Сообщение	Тип Журнала
spid52	Attempting to load library 'xplog70.dll' into memory.	SQL Server
spid52	Using 'xplog70.dll' version '2025.170.1000' to execute extended stored procedure 'xp_msver	SQL Server
spid52	Attempting to load library 'xpsqlbot.dll' into memory	SQL Server
spid52	Using 'xpsqlbot.dll' version '2025.170.1000' to execute extended stored procedure 'xp_qv'	SQL Server
spid75	Attempting to load library 'xpstar.dll' into memory.	SQL Server
spid75	Using 'xpstar.dll' version '2025.170.1000' to execute extended stored procedure 'xp_regread'.	SQL Server

Изучим средство мониторинга процесса Procmon. Посмотрим, удастся ли выявить активность, спровоцированную тестовым клиентским приложением. На рисунке 3 представлено дерево процессов консоли отладки среды программирования, через которое запускалась тестовая сборка приложения:

VsDebugConsole.exe (9140)	Visual Studio Deb...	C:\Program Files\...	Microsoft Corporat...	DESKTOP-FD4O...	"C:\Program Files...	03.05.2026 10:23:...	03.05.2026 10:33:...
conhost.exe (5220)	Хост окна консоли	C:\Windows\syst...	Microsoft Corporat...	DESKTOP-FD4O...	\??\C:\Windows\...	03.05.2026 10:23:...	03.05.2026 10:33:...
xpcmdshell.exe (2316)		C:\Users\johndou...		DESKTOP-FD4O...	"C:\Users\johndo...	03.05.2026 10:23:...	03.05.2026 10:33:...
cmd.exe (9772)	Обработчик ком...	C:\Windows\syst...	Microsoft Corporat...	DESKTOP-FD4O...	C:\Windows\syst...	03.05.2026 10:33:...	03.05.2026 10:33:...
xpcmdshell.exe (11140)		C:\Users\johndou...		DESKTOP-FD4O...	"C:\Users\johndo...	03.05.2026 10:33:...	03.05.2026 10:33:...

На рисунке 4 представлено дерево процессов sqlserver.exe, по которому можно явно определить выполненную команду и средство её исполнения

sqlservr.exe (3024)	SQL Server Windows NT - 64 Bit	C:\Program Files\...	Microsoft Corporat...	NT SERVICE\MS...	"C:\Program Files...	03.05.2026 10:18:...	n/a
cmd.exe (2768)	Обработчик команд Windows	C:\Windows\syst...	Microsoft Corporat...	NT SERVICE\MS...	"C:\Windows\syst...	03.05.2026 10:33:...	03.05.2026 10:33:...
Conhost.exe (9924)	Хост окна консоли	C:\Windows\Syst...	Microsoft Corporat...	NT SERVICE\MS...	\??\C:\Windows\...	03.05.2026 10:33:...	03.05.2026 10:33:...
whoami.exe (2464)	whoami - Отображение информации о вошедшем в систему пользователе	C:\Windows\syst...	Microsoft Corporat...	NT SERVICE\MS...	whoami	03.05.2026 10:33:...	03.05.2026 10:33:...

На основе собранных журналов и наблюдаемых артефактов можно заключить, что использование расширенной хранимой процедуры xp_cmdshell в Microsoft SQL Server не фиксируется напрямую в стандартных журналах SQL Server и Windows Event Log. В частности, отсутствуют явные записи, позволяющие однозначно идентифицировать факт вызова процедуры и определить выполняемую команду ОС.

При этом установлено, что выполнение сопровождается косвенными признаками, такими как загрузка библиотек, связанных с расширенным процедурами. Эти события позволяют зафиксировать сам факт использования расширенного функционала, однако не дают возможности восстановить точный сценарий выполняемых действий.

Дополнительно показано, что клиентское приложение, взаимодействующие с сервером через ODBC-интерфейс, может инициировать подобную активность, что подтверждает возможность удаленного воздействия на поведение системы при наличии соответствующих привилегий.

Использование средств расширенного мониторинга позволяет выявить связанную с данным механизм активность на уровне ОС, включая создание процессов и взаимодействие с системными ресурсами. Однако без дополнительной корреляции с событиями на уровне СУБД данные наблюдения не обеспечивают однозначной привязки к конкретному SQL-запросу.

Таким образом, обнаружение использования xp_cmdshell требует комплексного анализа нескольких источников данных и построения корреляции между событиями на уровне базы данных и операционной системы. Отсутствие прямых индикаторов в стандартных журналах усложняет задачу выявления подобных действий и требует применения специализированных средств мониторинга и анализа.

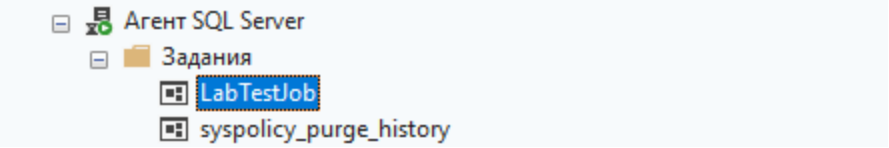
MS-SQL Agent Jobs

Запустив пользовательское приложение, и удостоверившись в корректном выполнении запроса, результат которого представлен на рисунке 5, можно перейти к исследованию средств журналирования.

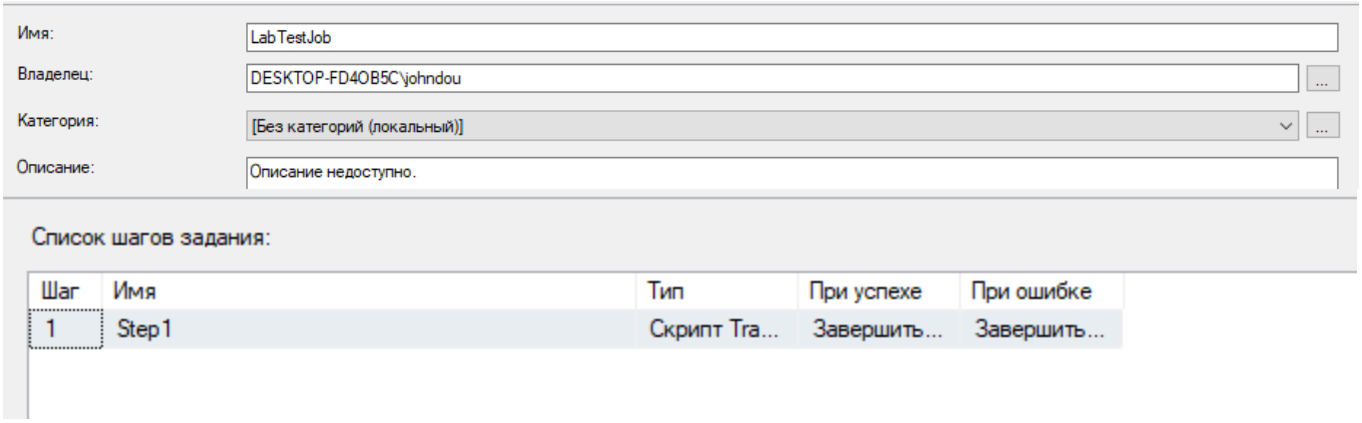
Активность заданий агента:

Имя	Включено	Состояние	Результат последнего запуска	Последний запуск	Следующий запуск	Категория	Готово к запуску	Запланировано	Идентификатор категории
syspolicy_purg...	да	Бездействие	Неизвестно	никогда	04.05.2026 2:00:00	[Без категорий (локальный)]	да	да	0
LabTestJob	да	Бездействие	Выполнено	03.05.2026 11:52:00	не запланировано	[Без категорий (локальный)]	да	да	0

В Miscrosoft SQL Server Management Studio в разделе "Агент SQL Server" можно найти созданную задачу для планировщика. Это показано на рисунке 6:



Свойства задания приведены на рисунках 7, 8, 9:



Список расписаний:

ID	Имя	Включе...	Описание	Задания в расписании
10	LabSchedule	Нет	Происходит 03.05.2026 в 0:00:00.	Представление

В журналах активности Агента SQL Server содержится запись: [162] Внутренний запрос (от SetJobNextRunDate [причина: расписание не будет выполняться повторно]) на деактивацию расписания 11. В журналах активности SQL Server записей, которые можно отнести к данному сценарию, не обнаружено. В Windows Event Log записей о работе SQL-агента нет.
Средство расширенного мониторинга активности показывает работу отдельного процесса SQLAGENT, представлено на рисунке 10:

SQLAGENT.EXE (3752)	SQLAGENT Application
conhost.exe (11640)	Хост окна консоли

Приведем детальную информацию о процессе в таблице 3:

Название	Данные
Описание	SQLAGENT Application
Компания	Microsoft Corporation
Путь	C:\Program Files\Microsoft SQL Server\MSSQL17.MSSQLSERVER\MSSQL\Binn\SQLAGENT.EXE
Пользователь	NT SERVICE\SQLSERVERAGENT

Результаты показали, что создание и выполнение задания SQL Server Agent фиксируется на уровне самой СУБД и её управляющих компонентов. Задание было успешно обнаружено в интерфейсе SQL Server Management Studio, с доступом к его свойствам, структуре шагов и параметрах выполнения.
Анализ журналов активности агента показал наличие записей, связанных с управлением заданием. При это в стандартных журналах SQL Server не было записей, указывающих на выполнение пользовательского задания. Аналогично, в системных журналах Windows Event Log отсутствуют события, позволяющие зафиксировать факт выполнения задания.
Средства мониторинга процессов на уровне операционной системы показали наличие отдельного процесса SQLAGENT.EXE, работающего по привилегиям учетной записи NT SERVICE\SQLSERVERAGENT. Анализ активности процесса в рамках эксперимента не позволяет напрямую связать его выполнение с конкретным заданием. Обнаружение использования SQL Server Agent требует смещение фокуса мониторинга на уровень базы данных.

OLE Automation

Запустив пользовательское приложение, и удостоверившись в корректном выполнении запроса, результат которого представлен на рисунке 11, перейдем к анализу системных журналов.

```
Attempting connection to SQL Server

Successfully Connected to SQL Server

Executing SQL query...

Query Result:
0

Press any key to exit...
```

Внутренняя система журналирования SQL Server содержит представленную в таблице 4 информацию о событии:

Название	Сведения
Журнал	Windows NT (System)

Название	Сведения
Источник	Microsoft-Windows-DistributedCOM
Категория	(0)
Событие	10016
Пользователь	NT SERVICE\MSSQLSERVER
Компьютер	DESKTOP-FD4OB5C
Сообщение	Параметры разрешений по умолчанию для компьютера не дают разрешения Локально Активация для приложения COM-сервера с CLSID {C2F03A33-21F5-47FA-B4BB-156362A2F239} и APPID {316CDED5-E4AE-4B15-9113-7055D84DCC97} пользователю NT SERVICE\MSSQLSERVER с ИД безопасности (S-1-5-80-3880718306-3832830129-1677859214-2598158968-1052248003) и адресом LocalHost (с использованием LRPC), выполняемого в контейнере приложения Недоступно с ИД безопасности (Недоступно). Это разрешение безопасности можно изменить с помощью средства администрирования служб компонентов.

Журнал Windows Event Log показывает информацию, собранную в таблице 5:

Название	Сведения
Имя журнала	Система
Источник	DistributedCOM
Код	10016
Уровень	Предупреждение
Пользователь	NT SERVICE\MSSQLSERVER
Компьютер	DESKTOP-FD4OB5C
Сообщение	Параметры разрешений по умолчанию для компьютера не дают разрешения Локально Активация для приложения COM-сервера с CLSID {C2F03A33-21F5-47FA-B4BB-156362A2F239} и APPID {316CDED5-E4AE-4B15-9113-7055D84DCC97} пользователю NT SERVICE\MSSQLSERVER с ИД безопасности (S-1-5-80-3880718306-3832830129-1677859214-2598158968-1052248003) и адресом LocalHost (с использованием LRPC), выполняемого в контейнере приложения Недоступно с ИД безопасности (Недоступно). Это разрешение безопасности можно изменить с помощью средства администрирования служб компонентов.

Результаты показали, что при попытке создания COM-объекта от имени службы SQL Server возникает событие в журнале Windows Event Log, связанное с подсистемой DistributedCOM (с кодом 10016). Данное событие указывает на отказ в предоставление прав локальной активации COM-сервера для учетной записи службы.
Анализ события показал, что несмотря на включенный механизм OLE Automation и наличие привилегий уровня sysadmin на стороне SQL Server, выполнение операции ограничивается механизмами безопасности операционной системы. В частности, политика DCOM запрещает активацию соответствующего COM-объекта из контекста службы SQL Server.
Использование OLE Automationзависит от дополнительного уровня контроля:

- выполнение операций может блокироваться на уровне ОС, даже при наличии привилегий в СУБД
- в системных журналах Windows появляются диагностические события, отражающие попытки несанкционированного доступа

- отсутствуют явные записи в журналах SQL Server, указывающие на характер выполняемой операции.
- наблюдаемость активности смещается на уровень ОС и требует анализа событий DCOM
  Полученный результат показывает, что механизм с одной стороны расширяет функциональность СУБД, но с другой его выполнение контролируется средствами безопасности Windows, что может как ограничить потенциально нежелательную активность, так и усложнить её анализ.

Методы защиты

В рамках проведенного эксперимента было установлено, что встроенные механизмы Microsoft SQL Server при определенной конфигурации могут использоваться для выполнения действий за пределами СУБД. Это требует применения комплексных мер защиты, охватывающих как уровень базы данных, так и уровень операционной системы.

xp_cmdshell

В стандартной конфигурации xp_cmdshell должен быть отключен. Если он включен, то его отключение можно спровоцировать через выполнение запроса EXEC sp_configure 'xp_cmdshell',0; RECONFIGURE;
В целом, данный механизм допустимо только в исключительных случаях, поэтому можно также ограничить привилегии: исключить пользователей из роли sysadmin, использовать принцип минимальных привилегий, настройка proxy-учетной записи для взаимодействия с xp_cmdshell с ограниченными правами.
Поскольку данный механизм инициирует запуск процессов, эффективным является мониторинг событий на уровне ОС. Также необходимо оценивать корреляцию событий с относящимися к загрузке xp_cmdshell-related библиотек в логах самого SQL Server. Комплексный подход при мониторинге позволит корректно определять злоупотребление возможностями расширенного функционала СУБД.

OLE Automation

Механизм OLE Automation обеспечивает взаимодействие SQL Server с COM-объектами Windows и обладает повышенной сложностью обнаружения.
Данный механизм должен быть отключен внутри самой СУБД при отсутствии явной необходимости использования.
Также проведенный эксперимент показал, что система безопасности Windows может ограничивать выполнение OLE-запросов через механизм DistributedCOM. Его события могут указывать на попытки несанкционированного взаимодействия с COM-объектами. Важно учитывать, что данные события не являются однозначным индикатором атаки и им требуется корреляция с другими источниками.
Так как выполнение происходит от имени учетной записи службы, рекомендуется минимизировать её привилегии и запретить доступ к критическим ресурсам ОС.

MS-SQL Agent Jobs

Механизм заданий SQL Server Agent может использоваться для закрепления активности в системе. Основным методом следует ограничить доступ к данной службе - запретить использование ролей SQLAgentOperatorRole, SQLAgentUserRole для непроверенных пользователей, - и контролировать права на создание и изменение заданий.
Так как все задания хранятся в системной базе msdb, её мониторинг позволяет отслеживать появление новых заданий, анализировать изменения существующих и контролировать расписание выполнения. Рекомендуется проводить аудит операций создания задания, изменения и запуска.
Несмотря на слабую наблюдаемость на уровне ОС, можно использовать журналы SQL Server Agent и корреляцию времени выполнения заданий с другими событиями системы.

Общий подход к защите

На основе проведенного анализа можно выделить ряд универсальных рекомендаций:

- Принцип минимальных привилегий
- Отключение неиспользуемого функционала
- Комплексный мониторинг

- Корреляция событий
- Изоляция среды

Заключение

В ходе выполнения данной курсовой работы были исследованы встроенные механизмы Microsoft SQL Server, потенциально применимые для выполнения операций на уровне операционной системы при наличии повышенных привилегий.

А) Был проведён анализ функциональности механизмов xp_cmdshell, OLE Automation и SQL Server Agent Jobs с точки зрения пост-эксплуатационного использования.
Б) Была развернута изолированная лабораторная среда и выполнены контролируемые эксперименты по активации указанных механизмов.
В) Были проанализированы артефакты, формируемые на уровне SQL Server, Windows Event Log и средств мониторинга операционной системы.
Г) Были выявлены особенности наблюдаемости данных механизмов и ограничения стандартных средств журналирования при попытке восстановления полной картины активности.
Д) Были сформированы практические рекомендации по снижению рисков злоупотребления функциональностью СУБД.

В результате установлено, что встроенные возможности Microsoft SQL Server могут представлять потенциальную поверхность атаки при неправильной конфигурации, однако их использование оставляет косвенные артефакты, позволяющие выявлять подобную активность при комплексном мониторинге.

Полученные результаты подтверждают необходимость применения принципов минимальных привилегий, отключения неиспользуемого функционала и корреляционного анализа событий из различных источников журналирования.

Работа может быть использована как основа для дальнейшего изучения пост-эксплуатационных техник в корпоративных СУБД и разработки методов их обнаружения.

Список литературы

- Microsoft. SQL Server Security Documentation. – Режим доступа: https://learn.microsoft.com/sql/sql-server/security/ (дата обращения: 03.05.2026).
- Microsoft. xp_cmdshell Server Configuration Option. – Режим доступа: https://learn.microsoft.com/sql/database-engine/configure-windows/xp-cmdshell-server-configuration-option (дата обращения: 03.05.2026).
- Microsoft. SQL Server Agent. – Режим доступа: https://learn.microsoft.com/sql/ssms/agent/sql-server-agent (дата обращения: 03.05.2026).
- Microsoft. Ole Automation Procedures Server Configuration Option. – Режим доступа: https://learn.microsoft.com/sql/database-engine/configure-windows/ole-automation-procedures-server-configuration-option (дата обращения: 03.05.2026).
- Microsoft. SQL Server Auditing (Database Engine). – Режим доступа: https://learn.microsoft.com/sql/relational-databases/security/auditing/sql-server-audit-database-engine (дата обращения: 03.05.2026).
- Russinovich M., Solomon D., Ionescu A. Windows Internals, Part 1. – Redmond: Microsoft Press, 7th Edition, 2017. – 944 с.
- Russinovich M., Solomon D., Ionescu A. Windows Internals, Part 2. – Redmond: Microsoft Press, 7th Edition, 2018. – 896 с.
- Howard M., LeBlanc D., Viega J. Writing Secure Code. – Redmond: Microsoft Press, 2nd Edition, 2002. – 768 с.
- NIST Special Publication 800-92. Guide to Computer Security Log Management. – National Institute of Standards and Technology, 2006. – 76 с.
- NIST Special Publication 800-53 Rev. 5. Security and Privacy Controls for Information Systems and Organizations. – 2020.
- Kim D., Solomon M. Fundamentals of Information Systems Security. – Burlington: Jones & Bartlett Learning, 2018. – 600 с.
- Chappel D. Understanding SQL Server Security Architecture. – Microsoft Technical Articles. – 2021.
- Microsoft. Windows Event Log Documentation. – Режим доступа: https://learn.microsoft.com/windows/win32/eventlog/event-logging (дата обращения: 03.05.2026).

- Sysinternals Suite Documentation. Process Monitor / Sysmon. – Microsoft. – Режим доступа: https://learn.microsoft.com/sysinternals/ (дата обращения: 03.05.2026).
- Casey E. Digital Evidence and Computer Crime. – Academic Press, 3rd Edition, 2011. – 800 с.
- Bishop M. Computer Security: Art and Science. – Addison-Wesley, 2003. – 1136 с.
- Stallings W., Brown L. Computer Security: Principles and Practice. – Pearson, 4th Edition, 2018. – 784 с.
- SANS Institute. Windows Logging Cheat Sheet. – 2022. – Режим доступа: https://www.sans.org/ (дата обращения: 03.05.2026).
- Splunk Inc. Windows Event Log Analysis Guide. – Technical Documentation, 2023.
- Redgate. SQL Server Security Best Practices. – Technical Whitepaper, 2022.